

ZÁKON O KYBERNETICKÉ BEZPEČNOSTI

Právní normy vztahující se ke KB

- Dokumenty EU/ES sloužící k harmonizaci právních úprav při řešení problematiky kybernetické bezpečnosti
 - Listina základních práv Evropské unie
- Směrnice Evropského parlamentu a Rady
 - 2016/1148 o opatřeních k zajištění vysoké společné úrovně bezpečnosti sítí a informačních systémů v Unii (NIS)
- Nařízení Evropského parlamentu a Rady
 - 910/2014 o elektronické identifikaci a službách vytvářejících důvěru pro elektronické transakce na vnitřním trhu a o zrušení směrnice 1999/93/ES (eIDAS)
 - 679/2016 o ochraně fyzických osob v souvislosti se zpracováním osobních údajů a o volném pohybu těchto údajů a o zrušení směrnice 95/46/ES (obecné nařízení o ochraně osobních údajů - GDPR)
 - Návrh nařízení o respektování soukromého života a ochraně osobních údajů v elektronických komunikacích a o zrušení směrnice 2002/58/ES (nařízení o soukromí a elektronických komunikacích – ePrivacy)
- Další dokumenty
 - Úmluva Rady Evropy č. 185 o kybernetické kriminalitě
- Mezinárodní normy
 - ISMS řady ISO/IEC 27000

Právní související s kybernetickou bezpečností

- **Právní normy ČR**

- **Zákon č. 40/2009 Sb., trestní zákoník**
- Zákon č. 418/2011 Sb., o trestní odpovědnosti právnických osob a řízení proti nim
- Zákon č. 141/1961 Sb., o trestním řízení soudním
- Zákon č. 218/2003 Sb., zákon o soudnictví ve věcech mládeže
- **Zákon č. 121/2000 Sb., autorský zákon**
- **Zákon č. 127/2005 Sb., o elektronických komunikacích**
- Zákon č. 480/2004 Sb., o některých službách informační společnosti
- Zákon č. 273/2008 Sb., o Policii České republiky
- **Zákon č. 89/2012 Sb., občanský zákoník**
- Zákon č. 101/2000 Sb., o ochraně osobních údajů
- Zákon č. 14/1993 Sb., o opatřeních na ochranu průmyslového vlastnictví
- Zákon č. 441/2003 Sb., o ochranných známkách
- Zákon č. 527/1990 Sb., o vynálezech, průmyslových vzorech a zlepšovacích návrzích
- **Zákon č. 300/2008 Sb., o elektronických úkonech a autorizované konverzi dokumentů, ve znění pozdějších předpisů**
- Zákon č. 297/2016 Sb., o službách vytvářejících důvěru pro elektronické transakce
- Zákon č. 160/1999 Sb., o svobodném přístupu k informacím
- **Zákon č. 181/2014 Sb., o kybernetické bezpečnosti a o změně souvisejících zákonů (zákon o kybernetické bezpečnosti)**

Dokumenty určující KB v ČR

- Zákon č. 181/2014 Sb. - Zákon o kybernetické bezpečnosti a o změně souvisejících zákonů (zákon o kybernetické bezpečnosti)
- Vyhláška č. 82/2018 Sb. - Vyhláška o bezpečnostních opatřeních, kybernetických bezpečnostních incidentech, reaktivních opatřeních, náležitostech podání v oblasti kybernetické bezpečnosti a likvidaci dat (vyhláška o kybernetické bezpečnosti)
- Vyhláška č. 317/2014 Sb. - Vyhláška o významných informačních systémech a jejich určujících kritériích
- Nařízení vlády č. 315/2014 Sb. - Nařízení vlády, kterým se mění nařízení vlády č. 432/2010 Sb., o kritériích pro určení prvku kritické infrastruktury

NÚKIB

- Národní úřad pro kybernetickou a informační bezpečnost
- V rámci novely ZoKB došlo k odštěpení Národního Centra Kybernetické Bezpečnosti (NKCB) od NBÚ a vzniku nového samostatného úřadu

Zákon o kybernetické bezpečnosti

- Cíl, jehož se ZoKB snaží dosáhnout, je zajištění bezpečného fungování české informační společnosti, tj. zajištění bezpečné realizace základního práva na informační sebeurčení a ochrana nedistributivních práv státu
- Zákon o kybernetické bezpečnosti **nezakládá civilní ani trestní odpovědnost pachatelů kybernetických útoků**
- Zákon o kybernetické bezpečnosti vytváří systém bezpečnostních opatření, která mají výskytu kybernetických bezpečnostních incidentů předcházet, resp. která mají zajistit, že případný kybernetický bezpečnostní incident neohrozí celkové fungování informačních a komunikačních systémů nebo fungování kriticky důležitých společenských informačních funkcionalit

Cíle zákona o kybernetické bezpečnosti

- Definování základní úrovně bezpečnostních opatření
- Zavedení detekce kybernetických bezpečnostních událostí
- Zavedení hlášení kybernetických bezpečnostních incidentů
- Vytvoření systému protiopatření k reakci na kybernetické bezpečnostní incidenty
- Definování činnosti dohledových pracovišť (národní CERT a vládní CERT)

Zákon o kybernetické bezpečnosti

- Zákon 181/2014 Sb.
 - Kdo co musí dělat
 - Co se musí dělat
- Vyhláška 82/2018
 - Detail opatření
 - Dokumentace
 - Incident

Zákon o kybernetické bezpečnosti

- Hlava I - Základní ustanovení
 - Nevztahuje se na IS a KS s utajovanými informacemi
 - Zapracovává příslušné předpisy EU
 - Definuje terminologické pojmy
 - Určuje, na koho se vztahuje zákon, tzv. povinné osoby

Zákon o kybernetické bezpečnosti

- Povinné osoby
 - Poskytovatelé služby elektronických komunikací
 - Správci Významných informačních systémů (VIS)
 - Správci Kritické informační infrastruktury (KII)
 - Provozovatelé základních služeb (PZS)
 - Poskytovatelé digitálních služeb (DSP)

Zákon o kybernetické bezpečnosti

- Poskytovatelé služby elektronických komunikací
 - Týká se jich soubor pravidel daných ZoKB a Prováděcím právním předpisem
 - Mají Zákon o elektronických komunikacích
 - Komunikují s Národním CERTem
 - 12 měsíců překlenovací lhůta od účinnosti ZoKB, tj. od 1.1.2016
 - Dělí se na dvě skupiny
 - Poskytovatelé zajišťující přímé zahraniční připojení do veřejné sítě nebo přímo připojují KII
 - Ostatní poskytovatele

Zákon o kybernetické bezpečnosti

- Významné informační systémy (VIS)
 - Jsou definovány podle určujících kritérií uvedených ve Vyhlášce o významných informačních systémech
 - 12 měsíců překlenovací lhůta od naplnění určujících kritérií VIS
 - Týká se jich soubor pravidel daných ZoKB a Prováděcím právním předpisem
 - Komunikují s Vládním CERTem

Zákon o kybernetické bezpečnosti

- Kritická informační infrastruktura (KII)
 - Jsou definovány podle určujících kritérií uvedených v Nařízení vlády č. 315/2014 Sb.
 - 12 měsíců překlenovací lhůta od naplnění určujících kritérií KII
 - Týká se jich soubor pravidel daných ZoKB a Prováděcím právním předpisem
 - Komunikují s Vládním CERTem
 - Mají rozdělen Informační systém (IS) od Komunikačního systému (KS)

Zákon o kybernetické bezpečnosti

- Provozovatel základních služeb
 - Velmi podobný KII
 - Definice vyhláškou č. 437/2017 Sb.

Zákon o kybernetické bezpečnosti

- Poskytovatel digitálních služeb
 - Vhodná a přiměřená bezpečnostní opatření
 - Prováděcí nařízení komise (EU) 2018/151 určuje pravidla definice bezpečnostních opatření při zohlednění rizik
 - on-line tržiště, internetového vyhledávače, cloud computing

Zákon o kybernetické bezpečnosti

VIS → PZS → KII

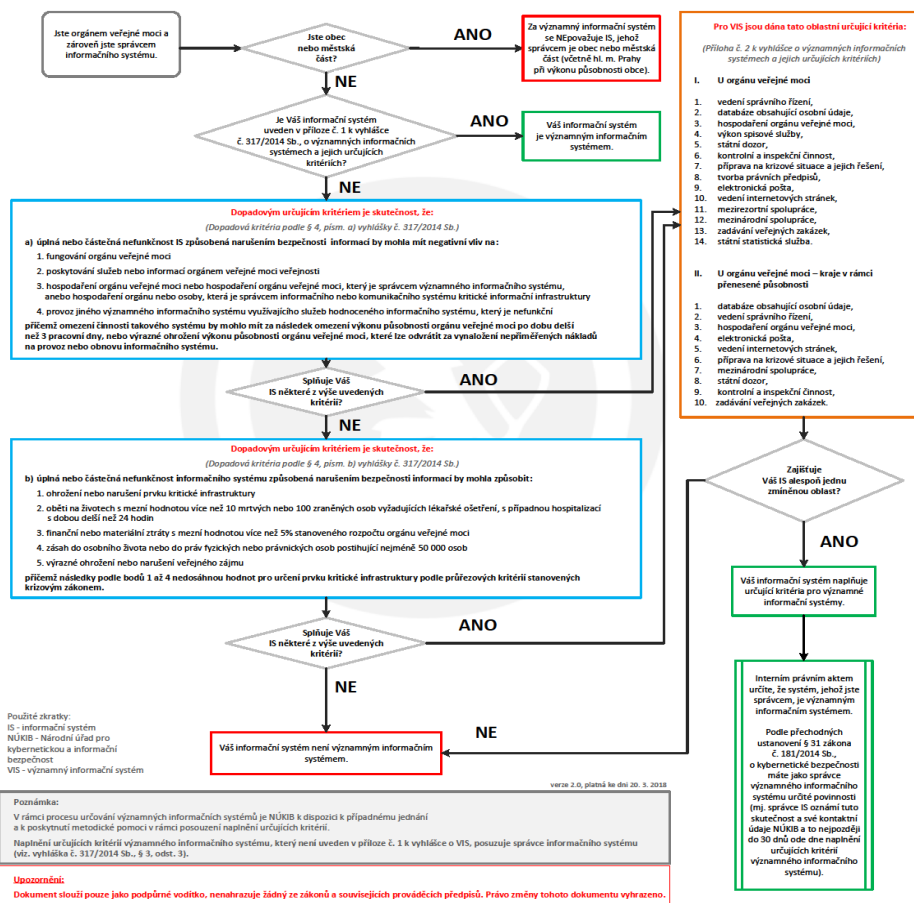
Zákon o kybernetické bezpečnosti

Významné informační systémy

Proces určování podle vyhlášky č. 317/2014 Sb., o významných informačních systémech a jejich určujících kritériích

Národní úřad
pro kybernetickou
a informační bezpečnost

NÚKIB



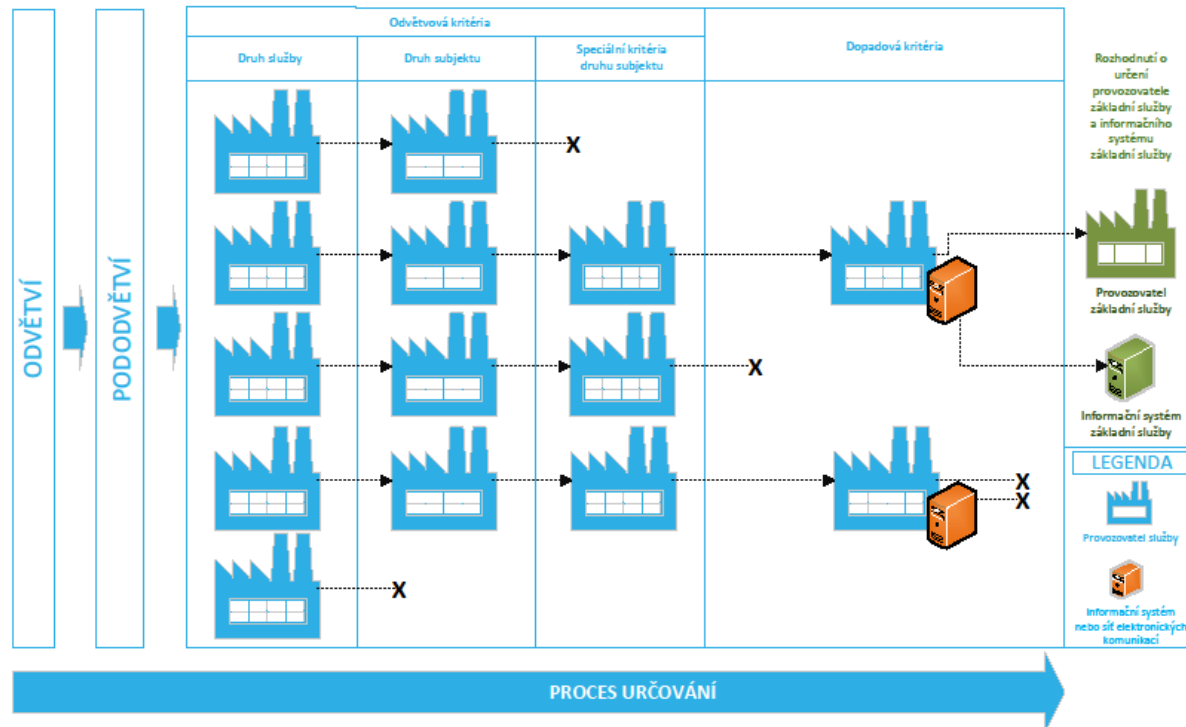
Zákon o kybernetické bezpečnosti

Základní služba

Národní úřad
pro kybernetickou
a informační bezpečnost



Proces určení provozovatele základní služby a informačního systému základní služby dle zákona o kybernetické bezpečnosti
a vyhlášky o kritériích pro určení provozovatelů základních služeb



Upozornění:

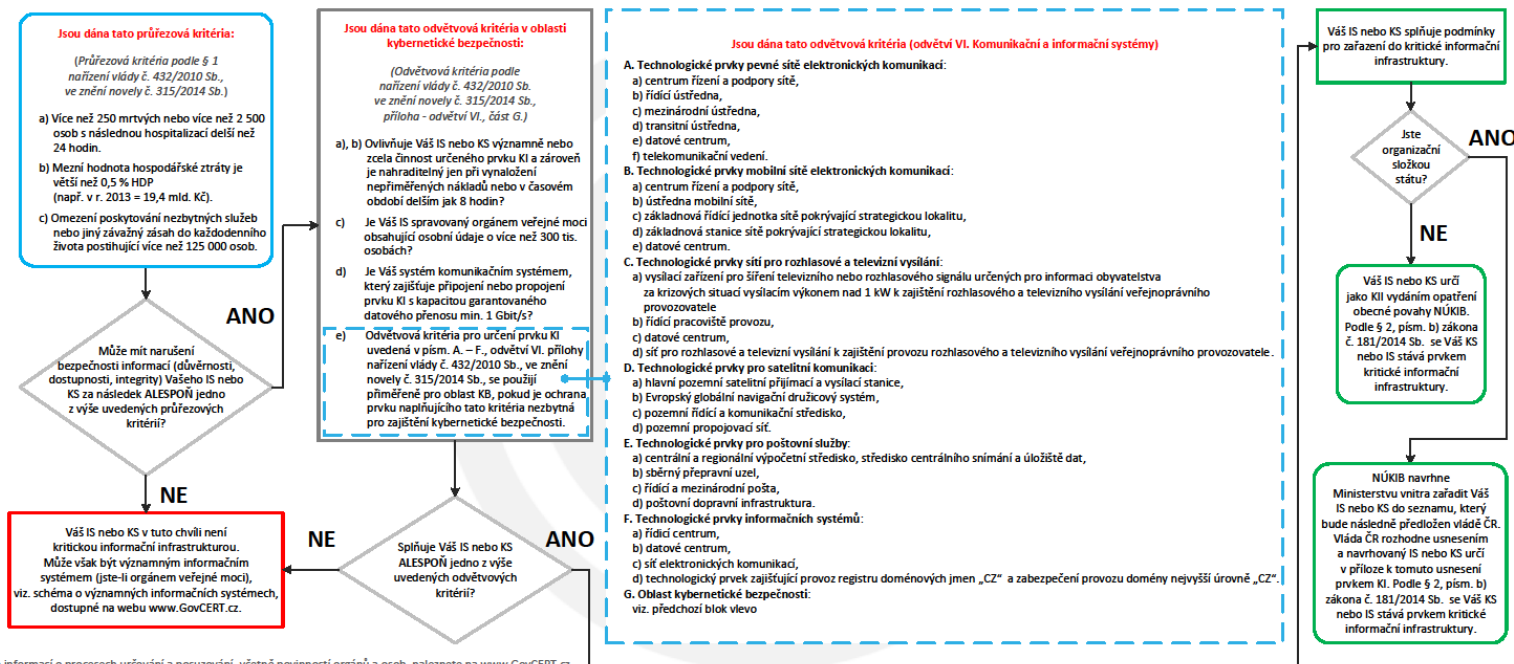
Dokument slouží pouze jako podpůrné vodítko, nenahrazuje žádný ze zákonů a souvisejících prováděcích předpisů. Právo změny tohoto dokumentu vyhrazeno.

Zákon o kybernetické bezpečnosti

Kritická informační infrastruktura

Proces určování podle zákona č. 240/2000 Sb., o krizovém řízení a o změně některých zákonů (krizový zákon) a nařízení vlády č. 432/2010 Sb., o kritériích pro určení prvku kritické infrastruktury ve znění novely č. 315/2014 Sb.

Národní úřad
pro kybernetickou
a informační bezpečnost



Více informací o procesech určování a posuzování, včetně povinností orgánů a osob, naleznete na www.GovCERT.cz

Použité zkratky: IS - informační systém, KB - kybernetická bezpečnost, KI - kritická infrastruktura, KII - kritická informační infrastruktura, KS - komunikační systém, NÚKIB - Národní úřad pro kybernetickou a informační bezpečnost, OOP - opatření obecné povahy

verze 2.0, platná ke dni 20. 3. 2018

Poznámka:

V rámci procesu určování kritické informační infrastruktury (KII) bude NÚKIB s dotčenými subjekty jednat a to již před samotným určením. Samotné určení pak proběhne, po oboustranném jednání. U organizačních složek státu probíhá určení prvku KII vydáním usnesení vlády ČR. U orgánů nebo osob, které nejsou organizační složkou státu, probíhá určení vydáním opatření obecné povahy (OOP), které vydá NÚKIB. NÚKIB je k dispozici k případnému jednání a k poskytnutí metodické pomoci v rámci posouzení naplnění určujících kritérií.

Upozornění:

Dokument slouží pouze jako podpůrné vodítko, nenahrazuje žádný ze zákonů a souvisejících prováděcích předpisů. Právo změny tohoto dokumentu vyhrazeno.

Zákon o kybernetické bezpečnosti

- Hlava II - Systém zajištění kybernetické bezpečnosti
 - Definuje povinnosti implementace bezpečnostních opatření
 - Popisuje KBU a KBI
 - Určuje způsob hlášení a evidence KBI
 - Stanovuje typy opatření před hrozbami a dopady KBI
 - Definuje práci s kontaktními údaji
 - Definuje, kdo je a co musí Národní/Vládní CERT

Zákon o kybernetické bezpečnosti

- Bezpečnostní opatření
 - Organizační opatření
 - Technická opatření

Zákon o kybernetické bezpečnosti

- Organizačními opatřeními jsou:
 - a) systém řízení bezpečnosti informací,
 - b) řízení rizik,
 - c) bezpečnostní politika,
 - d) organizační bezpečnost,
 - e) stanovení bezpečnostních požadavků pro dodavatele,
 - f) řízení aktiv,
 - g) bezpečnost lidských zdrojů,
 - h) řízení provozu a komunikací,
 - i) řízení přístupu osob,
 - j) akvizice, vývoj a údržba,
 - k) zvládání kybernetických bezpečnostních událostí a kybernetických bezpečnostních incidentů,
 - l) řízení kontinuity činností a
 - m) kontrola a audit.

Zákon o kybernetické bezpečnosti

- Technickými opatřeními jsou:
 - a) fyzická bezpečnost,
 - b) nástroj pro ochranu integrity komunikačních sítí,
 - c) nástroj pro ověřování identity uživatelů,
 - d) nástroj pro řízení přístupových oprávnění,
 - e) nástroj pro ochranu před škodlivým kódem,
 - f) nástroj pro zaznamenávání činnosti informačního nebo komunikačního systému, jeho uživatelů a administrátorů,
 - g) nástroj pro detekci kybernetických bezpečnostních událostí,
 - h) nástroj pro sběr a vyhodnocení kybernetických bezpečnostních událostí,
 - i) aplikační bezpečnost,
 - j) kryptografické prostředky,
 - k) nástroj pro zajišťování úrovně dostupnosti informací a
 - l) bezpečnost průmyslových a řídicích systémů.

Zákon o kybernetické bezpečnosti

- Kybernetická bezpečnostní událos (KBU)
 - Událost, která může způsobit narušení bezpečnosti
 - Není povinnost hlásit Národnímu/Vládnímu CERT
 - Je povinnost detekovat KBU u VIS a KII, a dále u poskytovatelů zajišťujících přímé zahraniční propojení do veřejné sítě nebo u těch, kde je přímo připojen KII a nově PZS (od novely v roce 2017)

Zákon o kybernetické bezpečnosti

- Kybernetická bezpečnostní incident (KBI)
 - Událost, která způsobila narušení bezpečnosti
 - Je povinnost hlásit Národnímu/Vládnímu CERTu bezodkladně po detekci
 - Prováděcí právní předpis stanovuje typy a kategorie KBI a formuláře pro hlášení
 - Evidenci KBI vede Vládní CERT
 - Zaměstnanci Vládního CERTu jsou vázáni mlčenlivosti pod sankcemi
 - Novinka – uložení povinnosti informovat veřejnost

Zákon o kybernetické bezpečnosti

- Opatření
 - Varování
 - Reaktivní opatření
 - Ochranné opatření

Zákon o kybernetické bezpečnosti

- Varování
 - O hrozbě v oblasti KB
 - Na webu Vládního CERTu + odeslání všem ovlivněným organizacím

Zákon o kybernetické bezpečnosti

- Reaktivní opatření
 - Musí být uloženo v souvislosti s ochrannou před KBI nebo k řešení KBI
 - Odesláno písemně, pokud do 3 dnů není doručení, následuje vyvěšení na úřední desce
 - Může být uloženo na místě ve správním řízení
 - Rozklad nemá odkladný účinek
 - U neurčité skupiny lze řešit opatřením obecné povahy
 - Ovlivněné organizace oznámí výsledek opatření
 - Způsob oznámení v Prováděcím předpisu

Zákon o kybernetické bezpečnosti

- Ochranné opatření
 - Na základě analýzy vyřešeného KBI nebo za účelem zvýšení bezpečnosti
 - Forma – Opatřené obecné povahy
 - Lhůta k provedení
 - Prakticky se jedná o dodatek k Prováděcímu právnímu předpisu